

■ Documentação da API

CliniDesk REST API — Referência de Endpoints (OpenAPI-style)

Projeto: CliniDesk — NPI

Versão: v1.0.0 · Sprint 2

Ano: 2026

Visão Geral da API

Campo	Valor
Base URL	http://localhost:5000/api
Formato	JSON (application/json)
Autenticação	Cookie HttpOnly com JWT (gerado no login)
Versão	v1.0.0
Servidor de Desenvolvimento	http://localhost:5000

■ ■ Autenticação

Todos os endpoints (exceto `/api/auth/login` e `/api/auth/register`) exigem autenticação. O token JWT é enviado automaticamente pelo navegador via cookie **HttpOnly**. O backend valida o cookie em cada requisição via `authMiddleware`. Em caso de token inválido ou expirado, a API retorna **HTTP 401** e o frontend redireciona ao login.

Autenticação

POST `/api/auth/login`

Login do usuário

Autentica o usuário com username e senha. Em caso de sucesso, define um cookie HttpOnly com o token JWT. Rate limiting: máximo 5 tentativas a cada 15 minutos por IP.

Request Body (application/json):

```
{ "username": "erlon", "password": "suaSenha123" }
```

Respostas:

Status	Descrição
200	Login bem-sucedido. Cookie HttpOnly definido. Retorna dados do usuário.
401	Credenciais inválidas.
429	Muitas tentativas. Tente novamente em 15 minutos.

POST `/api/auth/register`

Cadastro de novo usuário

Registra um novo usuário no sistema. Apenas administradores devem ter acesso a esta rota.

Request Body (application/json):

```
{ "username": "novo_usuario", "password": "senhaSegura456", "role": "recepcionista" }
```

Respostas:

Status	Descrição
201	Usuário criado com sucesso.
400	Dados inválidos ou username já em uso.

POST /api/auth/logout

Logout do usuário

Invalida a sessão limpando o cookie HttpOnly do navegador.

Respostas:

Status	Descrição
200	Logout realizado com sucesso.
401	Não autenticado.

Consultas

GET /api/pacientes/consultas

Listar todas as consultas

Retorna a lista completa de consultas agendadas, podendo ser filtrada por data ou setor via query params.

Parâmetros:

Nome	Local	Tipo	Descrição
data	query	string	Filtrar por data no formato YYYY-MM-DD
setor	query	string	Filtrar por setor (ex: geriatria, fisioterapia)

Respostas:

Status	Descrição
200	Array de objetos de consulta ordenados por horário.
401	Token inválido ou ausente.

POST /api/pacientes/consultas

Criar nova consulta

Cria um novo agendamento de consulta. Passa pelo middleware validateAgendamento antes do controller. Se os dados de retorno não forem preenchidos, as chaves de retorno são removidas antes da persistência.

Request Body (application/json):

```
{ "paciente": "Maria Silva", "telefonePaciente": "(81) 99999-9999", "responsavel": "João Silva", "telefoneResponsavel": "(81) 98888-8888", "data": "2026-07-15", "horario": "09:30", "setor": "geriatria", "dataRetorno": "2026-08-15", "horarioRetorno": "10:00" }
```

Respostas:

Status	Descrição
201	Consulta criada com sucesso. Retorna o objeto criado com _id.
400	Dados inválidos (validação do middleware).
401	Não autenticado.
422	Entidade não processável — dados opcionais com formato incorreto.

PUT /api/pacientes/consultas/:id

Atualizar consulta

Atualiza os dados de uma consulta existente pelo ID do MongoDB.

Parâmetros:

Nome	Local	Tipo	Descrição
id	path	string	ID do MongoDB da consulta (ObjectId)

Respostas:

Status	Descrição
200	Consulta atualizada com sucesso.
400	Dados inválidos.
401	Não autenticado.
404	Consulta não encontrada.

DELE
TE

/api/pacientes/consultas/:id

Cancelar/remover consulta

Remove permanentemente uma consulta pelo ID. Rota corrigida no Sprint 2 (erro 404 resolvido).

Parâmetros:

Nome	Local	Tipo	Descrição
id	path	string	ID do MongoDB da consulta (ObjectId)

Respostas:

Status	Descrição
200	Consulta removida com sucesso.
401	Não autenticado.
404	Consulta não encontrada.

PATC
H

/api/pacientes/consultas/:id/lembrete

Registrar envio de lembrete

Atualiza o campo de lembrete da consulta, gravando o ID do usuário que enviou e o timestamp do envio.

Parâmetros:

Nome	Local	Tipo	Descrição
id	path	string	ID do MongoDB da consulta (ObjectId)

Request Body (application/json):

```
{ "lembreteEnviadoPor": "userId", "lembreteEnviadoEm": "2026-07-15T09:00:00.000Z" }
```

Respostas:

Status	Descrição
200	Lembrete registrado com sucesso.
401	Não autenticado.
404	Consulta não encontrada.

Retornos

GET /api/pacientes/consultas/retornos

Listar todos os retornos

Retorna todos os agendamentos de retorno cadastrados.

Respostas:

Status	Descrição
200	Array de objetos de retorno.
401	Não autenticado.

DELETE /api/pacientes/consultas/retornos/:id

Remover retorno

Remove permanentemente um retorno pelo ID. Rota separada da de consultas para evitar conflito de rotas dinâmicas (corrigido Sprint 2).

Parâmetros:

Nome	Local	Tipo	Descrição
id	path	string	ID do MongoDB do retorno (ObjectId)

Respostas:

Status	Descrição
200	Retorno removido com sucesso.
401	Não autenticado.
404	Retorno não encontrado.

Códigos de Resposta HTTP

Código	Significado	Cenário comum no CliniDesk
200	OK	Operação realizada com sucesso
201	Created	Consulta ou usuário criado com sucesso
400	Bad Request	Dados inválidos — validação do middleware rejeitou a entrada
401	Unauthorized	Token ausente, inválido ou expirado

404	Not Found	ID de consulta ou retorno não encontrado no banco
422	Unprocessable Entity	Dados opcionais com formato incorreto (campo de retorno vazio)
429	Too Many Requests	Rate limit de login excedido (5 tentativas / 15 min)
500	Internal Server Error	Erro inesperado no servidor — verificar logs